SECURITY ASSESSMENT & RED TEAM AUDIT REPORT

Laporan Penetrasi & Audit Keamanan PWA MyLala

Analisis Kerentanan Arsitektur, Supabase RLS, Autentikasi Klien, & Skenario Serangan Bertingkat (Easy, Medium, Hard)

Target Aplikasi	MyLala PWA (Personal Langua Codebase)
Tipe Audit	White-Box Source Code Review & Red Team Threat Modeling
Ruang Lingkup	Frontend React 19, Supabase RLS Policies, Web Crypto Auth, Zustand Store, Vercel Config
Tanggal Audit	12 November 2026
Status Keamanan	**HIGH RISK / CRITICAL VULNERABILITIES DETECTED**
Klasifikasi Pengujian	Skenario Bertingkat: Tingkat Easy, Medium, dan Hard
Integritas Kode Target	**100% Read-Only** (Kode sumber tidak diubah satu karakter pun)

RINGKASAN EKSEKUTIF:
Berdasarkan audit komprehensif terhadap basis kode PWA MyLala, tim Red Team mengidentifikasi **sejumlah celah keamanan arsitektural kritis** yang berpusat pada **Row Level Security (RLS) Supabase yang terbuka penuh (public all)**, mekanisme autentikasi dan hashing yang dieksekusi secara murni di sisi klien (client-side crypto), serta ketiadaan validasi sisi server pada sistem skor leaderboard. Celah ini memungkinkan penyerang eksternal dengan kunci anonim bawaan untuk **mengunduh seluruh kredensial database akun pengguna**, melakukan **account takeover akun admin**, memanipulasi posisi juara liga klasemen, serta mengakses rute internal tanpa kredensial yang sah.

Tingkat Keparahan	Jumlah Temuan	Dampak Utama	SLA Remediasi
■ CRITICAL	**3 Temuan**	Dump kredensial massal, Admin Takeover, Manipulasi RLS	**< 24 Jam**
■ HIGH	**3 Temuan**	Manipulasi Leaderboard/XP, Weak SHA256, Content Defacement	**< 72 Jam**
■ MEDIUM	**2 Temuan**	Bypass Route LocalStorage, Data PII di Service Worker Cache	7 Hari
■ LOW / INFO	**1 Temuan**	Missing Security Headers (Clickjacking & CSP)	14 Hari

1. Skenario Penetrasi Level EASY (Tingkat Rendah / Tanpa Autentikasi)

Skenario pada level ini memiliki kompleksitas penyerangan rendah, tidak memerlukan akses autentikasi sebelumnya, dan dapat dieksploitasi dengan memanfaatkan miskonfigurasi langsung pada REST API.

Skenario 1.1: Ekstraksi Massal Database Kredensial via Miskonfigurasi RLS (user_accounts)
• **Vektor & Titik Kelemahan:** File supabase_sync_fix.sql baris 26-27 mendefinisikan policy:
CREATE POLICY "Allow public all for user_accounts" ON user_accounts FOR ALL USING (true) WITH CHECK (true);
• **Mekanisme Eksploitasi Konseptual:** Kunci publik Supabase anon key dan URL proyek terekspos secara publik di file src/services/supabase.js dan bundle JavaScript PWA. Penyerang cukup mengirimkan HTTP GET standar ke endpoint REST Supabase:
GET /rest/v1/user_accounts?select=* HTTP/1.1
• **Dampak Nyata:** Database akan mengembalikan seluruh baris data pengguna tanpa filter, mencakup: id, username, email, name, role, salt, dan password_hash.
• **Tingkat Risiko:** **CRITICAL (CVSS: 9.8)**

Skenario 1.2: Manipulasi Integritas Leaderboard & Injeksi Skor XP Fiktif (user_weekly_stats)
• **Vektor & Titik Kelemahan:** File supabase_leaderboard.sql baris 35-37 membuka akses penuh FOR ALL ke tabel user_weekly_stats. Selain itu, penghitungan XP di useAppStore.js baris 774-798 sepenuhnya dieksekusi di memori browser klien tanpa verifikasi keabsahan kuis di server.
• **Mekanisme Eksploitasi Konseptual:** Siapa pun dapat mengirimkan HTTP POST atau PATCH dengan payload JSON yang memuat weekly_xp: 9999999 dan streak: 999 untuk nama user apa pun.
• **Dampak Nyata:** Integritas gamifikasi dan sistem liga rusak total. Penyerang dapat mendepak pengguna yang belajar secara jujur dari peringkat 1 Diamond League.
• **Tingkat Risiko:** **HIGH (CVSS: 7.5)**

Skenario 1.3: Bypass Rute Terproteksi Klien via Modifikasi LocalStorage Browser
• **Vektor & Titik Kelemahan:** Komponen ProtectedRoute.jsx hanya memeriksa nilai Boolean isAuthenticated dari store Zustand yang disimpan di localStorage.getItem('personal_langua_storage').
• **Mekanisme Eksploitasi Konseptual:** Pengguna yang belum terdaftar membuka console browser pengembang dan menyunting state lokal:
const s = JSON.parse(localStorage.getItem('personal_langua_storage') || '{}');
s.state = { ...s.state, isAuthenticated: true, user: { role: 'admin', username: 'admin' } };
localStorage.setItem('personal_langua_storage', JSON.stringify(s)); location.reload();
• **Dampak Nyata:** Penyerang dapat langsung melewati form login dan mengakses UI privat (halaman dashboard, latihan, dan pembuatan modul custom /create).
• **Tingkat Risiko:** **MEDIUM (CVSS: 6.5)**

2. Skenario Penetrasi Level MEDIUM (Kompleksitas Logika & Kriptografi)

Skenario pada tingkat ini melibatkan analisis algoritma kriptografi yang digunakan aplikasi, analisis penyimpanan lokal Service Worker, dan perusakan data antar pengguna.

Skenario 2.1: Pemulihan Password Offline via Cracking Algoritma Single-Round SHA-256

- **Vektor & Titik Kelemahan:** File src/utils/cryptoAuth.js baris 33 mengimplementasikan hashing klien:
  const data = enc.encode(`${salt}:${password}:mylala_pwa_secret_2026`);
  crypto.subtle.digest('SHA-256', data);
- **Kelemahan Kriptografi:** SHA-256 adalah fungsi digest yang dirancang cepat, **bukan** fungsi Password KDF (seperti Argon2id, bcrypt, atau PBKDF2). Selain itu string 'secret' (pepper) bersifat hardcoded statis di file frontend.
- **Mekanisme Eksploitasi Konseptual:** Setelah penyerang mengunduh hash dan salt melalui Skenario 1.1, penyerang memasukkan format hash ke software recovery GPU (Hashcat/John the Ripper). Dengan kecepatan kartu grafis modern yang mencapai puluhan miliar hash/detik, password standar 6-10 karakter dapat dipecahkan dalam hitungan menit hingga jam.
- **Tingkat Risiko:** **HIGH (CVSS: 7.4)**

Skenario 2.2: Kebocoran Data Sensitif & Akun Pengguna pada CacheStorage Service Worker PWA

- **Vektor & Titik Kelemahan:** File vite.config.js baris 53-67 mengonfigurasi caching otomatis Workbox:
  urlPattern: /^https:\/\/.*\.supabase\.co\/rest\/v1\/.*/i
  handler: 'NetworkFirst', maxAgeSeconds: 604800 (7 hari)
- **Mekanisme Eksploitasi Konseptual:** Saat PWA berjalan di perangkat bersama (shared device/warnet/laptop bersama), respon REST API yang memuat data profil atau akun pengguna tersimpan unencrypted di CacheStorage browser dan tidak terhapus saat fungsi logout() dipanggil.
- **Dampak Nyata:** Pengguna berikutnya pada perangkat yang sama dapat mengekstrak data histori respon API pengguna sebelumnya langsung dari penyimpanan cache offline browser.
- **Tingkat Risiko:** **MEDIUM (CVSS: 5.3)**

Skenario 2.3: Perusakan & Penghapusan Massal Progres Belajar (user_progress Table Tampering)

- **Vektor & Titik Kelemahan:** File supabase_schema.sql baris 68-69:
  CREATE POLICY "Allow public insert/update for user_progress" ON user_progress FOR ALL USING (true) WITH CHECK (true);
- **Mekanisme Eksploitasi Konseptual:** Penyerang dapat mengirimkan permintaan HTTP DELETE atau UPDATE ke tabel user_progress dengan parameter user_id=eq.[target_user_id].
- **Dampak Nyata:** Penyerang dapat mereset data algoritma SRS (Spaced Repetition System) milik siswa lain menjadi nol atau mengacaukan jadwal pengulangan kartu belajar.
- **Tingkat Risiko:** **HIGH (CVSS: 7.1)**

3. Skenario Penetrasi Level HARD (Rantai Serangan Lanjutan / Chained Exploits)

Skenario tingkat tinggi ini menggabungkan beberapa kelemahan arsitektur secara berurutan untuk mencapai dampak kompromi total (Full Account Takeover & Infrastructure Defacement).

Skenario 3.1: Rantai Serangan Pengambilalihan Akun Administrator Tanpa Kata Sandi (Full Admin Takeover)
Rantai eksploitasi multi-tahap:
1. **Tahap Reconnaissance:** Penyerang membaca tabel user_accounts dan menemukan akun admin default: username: imam, id: admin-imam-001, role: admin.
2. **Tahap Modifikasi Hash (Direct DB Tamper):** Karena policy RLS mengizinkan operasi FOR ALL, penyerang membuat hash SHA-256 dari password yang diketahuinya sendiri (misal: 'hacked123') dengan salt baru.
3. **Tahap Injeksi Kredensial:** Mengirim HTTP PATCH ke Supabase:
PATCH /rest/v1/user_accounts?username=eq.imam
Payload: { "password_hash": "[hash_baru]", "salt": "[salt_baru]" }
4. **Tahap Login & Otentikasi:** Penyerang membuka PWA di browser apa pun, memasukkan username 'imam' dan password baru. Karena fungsi login() di useAppStore.js menggunakan strategi **Cloud-First** (mengecek ke tabel cloud user_accounts terlebih dahulu), verifikasi password dinyatakan SUKSES.
• **Dampak Nyata:** Pengambilalihan penuh akun admin tanpa memecahkan password asli sama sekali.
• **Tingkat Risiko:** **CRITICAL (CVSS: 9.9)**

Skenario 3.2: Defacement Modul Kurikulum & Social Engineering Stored Content Injection
• **Vektor & Titik Kelemahan:** Script scripts/seed-starter-modules.js membuktikan bahwa operasi upsert pada tabel modules dan flashcards dapat dijalankan langsung menggunakan kunci anonim.
• **Mekanisme Serangan Lanjutan:** Penyerang menyisipkan konten markdown berbahaya atau link phishing tersembunyi ke dalam materi modul cheat sheet grammar (misal: content_markdown pada modul TOEFL). Saat siswa membuka modul tersebut, aplikasi merender konten yang telah disabotase.
• **Dampak Nyata:** Perusakan integritas kurikulum pembelajaran publik, potensi reputasi rusak, dan risiko phishing terarah terhadap seluruh siswa MyLala.
• **Tingkat Risiko:** **HIGH (CVSS: 7.1)**

Skenario 3.3: Serangan Clickjacking & UI Redressing (Ketiadaan Header Proteksi Framing)
• **Vektor & Titik Kelemahan:** File vercel.json dan index.html sama sekali tidak mendefinisikan header X-Frame-Options: DENY maupun Content Security Policy dengan arahan frame-ancestors 'none'.
• **Mekanisme Eksploitasi Konseptual:** Penyerang membuat web jebakan yang memuat iframe transparan PWA MyLala (misalnya tombol 'Hapus Akun' atau tombol aksi kartu). Pengguna yang mengklik game/kuis di website jebakan tanpa sadar mengklik tombol di dalam PWA MyLala.
• **Dampak Nyata:** Eksekusi aksi tak diinginkan atas nama pengguna yang sedang aktif login.
• **Tingkat Risiko:** **MEDIUM (CVSS: 6.1)**

4. Tabel Komprehensif Temuan Kerentanan (CVSS v3.1)

Berikut adalah ringkasan teknis dari seluruh kelemahan keamanan yang diidentifikasi selama pengujian white-box red team:

ID	Judul Temuan	CWE ID	CVSS	Level
VULN-01	RLS Terbuka Penuh pada Tabel Kredensial user_accounts	CWE-284 CWE-306	**9.8**	**EASY**
VULN-02	Rantai Serangan Pengambilalihan Akun Admin Tanpa Password	CWE-287 CWE-640	**9.9**	**HARD**
VULN-03	Hardcoded Default Kredensial Admin & Salt Statis	CWE-798	**8.2**	**EASY**
VULN-04	Manipulasi XP Leaderboard Tanpa Validasi Server	CWE-602	**7.5**	**EASY**
VULN-05	Algoritma Single-Round SHA-256 Rentan Terhadap GPU Cracking	CWE-916	**7.4**	**MEDIUM**
VULN-06	Izin Menulis Publik pada Tabel Kurikulum (Modul & Flashcard)	CWE-285	**7.1**	**HARD**
VULN-07	Bypass Autentikasi Rute Klien via LocalStorage Manipulation	CWE-603	**6.5**	**EASY**
VULN-08	Ketiadaan HTTP Security Headers (Clickjacking & CSP Exposure)	CWE-1021	**6.1**	**HARD**
VULN-09	Penyimpanan REST API Respon Tak Terenkripsi di Cache Service Worker	CWE-312	**5.3**	**MEDIUM**

5. Panduan & Rekomendasi Remediasi Teknis (Roadmap Perbaikan)

Untuk menutup celah-celah kritis yang ditemukan secara permanen, ikuti cetak biru perbaikan teknis berikut:

1. Migrasi Penuh ke Supabase Auth Resmi & Kunci RLS dengan auth.uid()
• **Masalah:** Menyimpan tabel kredensial manual (user_accounts) dengan password hash di database SQL yang dibuka ke publik adalah anti-pattern berisiko fatal.
• **Solusi Pasti:** Hentikan penggunaan tabel user_accounts kustom. Gunakan sistem autentikasi bawaan Supabase (**GoTrue Auth**) yang menangani hashing bcrypt/argon2 di server yang aman.
• **Perbaikan RLS pada Tabel user_weekly_stats & user_progress:**

```
-- Kunci akses tulis hanya untuk pemilik ID yang telah terotentikasi secara sah
ALTER TABLE user_weekly_stats ENABLE ROW LEVEL SECURITY;
DROP POLICY IF EXISTS "Allow public all for user_weekly_stats" ON user_weekly_stats;

CREATE POLICY "Public can read leaderboard" ON user_weekly_stats
    FOR SELECT USING (true);

CREATE POLICY "Users can only update their own stats" ON user_weekly_stats
    FOR ALL USING (auth.uid()::text = user_id)
    WITH CHECK (auth.uid()::text = user_id);

-- Kunci tabel modules agar hanya admin resmi yang dapat mengedit kurikulum
ALTER TABLE modules ENABLE ROW LEVEL SECURITY;
CREATE POLICY "Public read modules" ON modules FOR SELECT USING (true);
CREATE POLICY "Only admin write modules" ON modules
    FOR ALL USING (auth.jwt() ->> 'role' = 'admin');
```

2. Terapkan Security Headers di vercel.json
Tambahkan konfigurasi header pertahanan berlapis untuk menangkal Clickjacking, MIME-sniffing, dan injeksi iframe berbahaya:

```
{
  "headers": [
    {
      "source": "/(.*)",
      "headers": [
        { "key": "X-Frame-Options", "value": "DENY" },
        { "key": "X-Content-Type-Options", "value": "nosniff" },
        { "key": "Referrer-Policy", "value": "strict-origin-when-cross-origin" },
        { "key": "Strict-Transport-Security", "value": "max-age=31536000; includeSubDomains" },
        { "key": "Content-Security-Policy", "value": "frame-ancestors 'none'; object-src 'none';"
}
      ]
    }
  ]
}
```

3. Kecualikan Endpoint Akun & Profil Pribadi dari Service Worker CacheStorage
Di file vite.config.js, pastikan endpoint REST Supabase yang menangani data pengguna pribadi tidak di-cache secara permanen di disk peramban. Hanya data statis seperti modules dan flashcards publik yang diizinkan untuk offline runtime caching.

PENTESTER ATTESTATION & SIGN-OFF:
Audit ini diselesaikan dengan mode strictly read-only sesuai mandat pengguna. Seluruh file sumber pada direktori target tetap utuh 100%. Laporan ini diterbitkan sebagai panduan prioritas hardening sebelum sistem MyLala PWA diluncurkan ke lingkungan produksi publik.